

Final Security Assessment

Basic ERC-20 Rehearsal Fixture

Report version	v2
Exact source	CurveYield/Contracts @ 248e5d5d...833331
Campaign	deep-assurance-v16-2-erc20-rehearsal-v2
Completion status	COMPLETE
Security verdict	NO_GO

NO_GO is caused by a mandatory assurance-evidence gate failure, not by a validated Critical/High/Medium/Low source vulnerability.

Independent AI-generated security assessment. OpenZeppelin-inspired structure; no OpenZeppelin affiliation or certification.

Important Notice and Engagement Metadata

This report is an independent AI-generated security assessment following an OpenZeppelin-inspired professional structure. It is not issued, endorsed, reviewed, or certified by OpenZeppelin, and no OpenZeppelin logo or affiliation is asserted. The assessment is point-in-time and cannot guarantee absence of defects.

This engagement is a rehearsal of Deep Assurance v16.2 on a synthetic basic ERC-20 fixture. The operator explicitly required a single ChatGPT runtime to execute all agent roles serially and prohibited polls. Accordingly, the role-separation steps were exercised, but production clean-room independence and cross-session reviewer independence were not demonstrated. Local dependency installation and local Solidity compilation were not performed.

Executive Summary

The audited fixture is a fixed-supply, dependency-free ERC-20-style token with three state-changing entry points: `transfer`, `approve`, and `transferFrom`. It has no owner, administrator, proxy, upgrade authority, callback, external protocol dependency, oracle, fee logic, mint path after construction, or burn path. Manual architecture, implementation, and economic review found no Critical, High, Medium, or Low severity source vulnerability.

The exact source successfully passed the Deep Assurance pinned `github-native-compile-v1` profile. The normalized compile result was PASSED, compiler diagnostics were empty, and the downloaded artifact digest matched GitHub metadata exactly. A separate auxiliary GitHub-runner lifecycle execution also passed 13 ERC-20 checks, but the required `github-native-simulate-v1` profile did not produce admissible normalized simulation evidence after two bounded exact-source dispatches. Deep Assurance v16.2 treats that missing mandatory evidence as a failed gate. Therefore the campaign completes with **securityVerdict: NO_GO**, even though there is no validated blocking source-code finding.

Findings counts

Class	Count
Critical	0
High	0
Medium	0
Low	0
Note	2
Client-Reported	0

The two Notes concern conventional ERC-20 allowance replacement semantics and a zero-value `transferFrom(address(0), recipient, 0)` event edge. Neither changes token supply or creates an unauthorized token-loss path.

Exact Source and Scope

- Repository: `CurveYield/Contracts`
- Exact commit: `248e5d5de42f8a111050fb8d2b7d587653833331`
- Project path: `audit-fixtures/deep-assurance-v16-2-erc20`
- File: `BasicERC20Rehearsal_v1.sol`

- Git blob SHA: 0527d19901a07a12911f3a212ee2664df8219afc
- Exact source SHA-256 from pinned compile manifest:
45f03e840b749f0d34255402aacc3045a51dede8c6a08cafc7a83242c7c9ee9c
- Full-file review boundary: the entire single Solidity file.
- Original source ZIP: not applicable; the rehearsal fixture was created and frozen directly in GitHub.
- Out of scope: production contracts, deployed addresses, live production state, unrelated repository files, and real poll/task orchestration.

Reproduction identities

- Deep Assurance skill: ai-auditor-deep-assurance-v6@16.2.0
- Controller: CurveYield/audit-controller@d09a925d4735da8acde24baf39a1de2fb90ddd2f
- Contract Automation bridge: ffb482b9b2ec5bff57921e3c13bafd0ee64f1aed
- Contract Automation finalized base: ad11d7d5a623c1411cbabb4bb0cd9acf7975bce8
- Runner manifest SHA-256: 51fc7ef486a75a0593aaf9f8b54965424785e34198479f4ee74dd88168f53292

Methodology and Assurance Boundaries

The rehearsal executed the seven Deep Assurance lane functions serially: scope/specification, architecture/threat modeling, manual implementation review, economic/accounting review, build/simulation evidence review, adversarial no-go review, and controller-owned final reconciliation. Distinct separate-review passes challenged the first-pass analytical submissions, technical-evidence disposition, adversarial finding set, and finalization snapshot.

Because the operator required one runtime and no polls, these review passes are procedural separations rather than evidence of independent model sessions. No claim of production clean-room independence is made.

Technical execution was evidence-gated. The pinned compile request used the exact source commit and was accepted only after checking classifier selection, selected/skipped job state, normalized result, source manifest, tool versions, artifact digest, and empty compiler diagnostics. Two pinned simulation requests were dispatched but did not yield the required normalized Deep Assurance simulation evidence. An auxiliary GitHub lifecycle run was retained as corroboration only and was not substituted for the mandatory profile.

System Overview

BasicERC20RehearsalV1 initializes a fixed token supply in its constructor and credits all units to the deployer. Holders can transfer their own tokens directly. An owner can assign a spender allowance through `approve`; an approved spender can use `transferFrom` up to that allowance. Finite allowances decrement on spend, while `type(uint256).max` is treated as an infinite allowance sentinel and remains unchanged.

All token movement passes through `_transfer`. The function rejects the zero recipient, checks the source balance, updates balances, and emits `Transfer`. The contract performs no external call during state mutation. There is no privileged administrative path and no post-construction supply-changing function.

Security Considerations and Threat Model

Assets and invariants

The only economic asset is the DART ledger balance. The central invariant is that the sum of reachable balances equals immutable totalSupply. Additional invariants are that a direct transfer can spend only the caller's balance, transferFrom can spend only the owner's authorized allowance, failed operations revert atomically, and no privileged actor can create or seize supply.

Untrusted actors

Any external account may call the public ERC-20 functions and choose recipient, spender, source, and amount inputs subject to contract checks. There are no trusted administrators or semi-trusted keepers.

Major attack surfaces reviewed

- authorization bypass through allowance storage;
- balance underflow or recipient overflow;
- self-transfer storage aliasing;
- MaxUint allowance handling;
- partial state persistence after a later revert;
- zero-address transfer semantics;
- reentrancy or callback paths;
- hidden mint, burn, pause, seizure, upgrade, or arbitrary-call authority.

No blocking attack path was validated.

Findings Summary

ID	Title	Class	Status	Affected component
N-01	Conventional ERC-20 allowance replacement race	Note	Open / documented	approve
N-02	Zero-value transferFrom can emit Transfer from address(0)	Note	Open / documented	transferFrom, _transfer

Critical: **0**. High: **0**. Medium: **0**. Low: **0**. The campaign's NO_G0 verdict is caused by mandatory assurance Gate 07, not by a blocking source finding.

Notes & Additional Information

N-01 - Conventional ERC-20 allowance replacement race

Severity: Note **Status:** Open / documented **Affected code:** approve, lines 63-68.

The contract implements the conventional overwrite-style `approve(spender, amount)` behavior. If a holder changes an existing nonzero allowance directly to another nonzero value, a spender can potentially front-run the replacement and consume the old allowance before the new approval lands. This is a well-known ERC-20 interface semantic rather than a privilege bypass unique to this fixture.

Recommendation: Integrations may use a zero-then-set approval sequence or a UX that clearly communicates allowance replacement risk. This is not treated as a launch blocker for this basic fixture.

N-02 - Zero-value `transferFrom` can emit `Transfer from address(0)`

Severity: Note **Status:** Open / documented **Affected code:** `transferFrom`, lines 70-83; `_transfer`, lines 85-97.

When `amount == 0`, both `allowance[address(0)][spender]` and `balanceOf[address(0)]` default to zero and satisfy the comparison checks. Because `_transfer` rejects only a zero **recipient**, `transferFrom(address(0), nonzeroRecipient, 0)` can complete and emit a zero-value `Transfer` event whose `from` field is the zero address. The auxiliary GitHub lifecycle execution reproduced this behavior. No balance or supply changes occur.

Recommendation: If strict event/indexer semantics are desired, explicitly reject `from == address(0)` in `_transfer` or `transferFrom`; otherwise document that zero-value calls may emit this event pattern.

Recommendations

R-01 - Use safer allowance-update UX

Prefer zero-then-set allowance changes or an equivalent user-facing pattern when changing an existing nonzero approval.

R-02 - Decide zero-source event semantics explicitly

Either reject a zero source for all transfers or document that zero-value `transferFrom` can produce a zero-address `Transfer` event without minting.

R-03 - Obtain accepted pinned simulation evidence before relying on a PASS verdict

Rerun `github-native-simulate-v1` against the same exact source revision and accept the normalized evidence before changing the failed Gate 07 disposition.

Remediation Review

No Critical, High, Medium, or Low source finding required remediation, and no fix commit was supplied. N-01 and N-02 are Notes with optional hardening/documentation recommendations. The missing pinned simulation evidence is an assurance-process gap rather than a source-code remediation item and remains unresolved in this report.

Deep Assurance Results and Process Exceptions

Phase results

Phase	Gate	Status	Outcome
1	exact-scope-provenance-complete	PASS	Exact GitHub source commit and file identity frozen.

Phase	Gate	Status	Outcome
2	risk-specification-complete	PASS	Actors, assets, invariants, edge cases and negative requirements accepted.
3	architecture-threat-model-complete	PASS	No hidden privilege, callback, dependency or upgrade boundary found.
4	manual-implementation-review-complete	PASS	All source transitions reviewed; two non-material observations retained.
5	economic-mathematical-review-complete	PASS	Fixed-supply conservation and arithmetic bounds established.
6	exact-build-and-tests-complete	PASS	Pinned github-native-compile-v1 evidence passed with empty diagnostics.
7	fork-simulation-lifecycle-complete	FAIL	Required github-native-simulate-v1 evidence did not materialize after two bounded dispatches.
8	findings-validation-complete	PASS	Canonical set reconciled to N-01 and N-02; no C/H/M/L finding.
9	remediation-review-complete	PASS	No blocking source remediation required or supplied.
10	release-and-report-complete	PENDING_AT_REPORT_BUILD	Publication occurs after PDF/Markdown/archive generation and fetch-back.

Lane results

Role	Terminal disposition	Evidence
scope-specification-auditor	ACCEPTED	Agent 1 v2
architecture-threat-auditor	ACCEPTED	Agent 2 v2
manual-implementation-auditor	ACCEPTED	Agent 3 v2
economic-accounting-auditor	ACCEPTED	Agent 4 v2
build-simulation-evidence-auditor	ACCEPTED - terminal evidence gap	Agent 5 v2
adversarial-no-go-auditor	ACCEPTED	Agent 6 v2
final-report-coordinator	ACCEPTED prepublication snapshot	Controller-owned snapshot v2

General errors

1. A transient GitHub connector write error occurred on the first finalization-snapshot upload attempt. The identical write was retried once and succeeded. No content divergence resulted.

Process-stopping errors

1. **Pinned simulation evidence unavailable:** two exact-source github-native-simulate-v1 requests were committed, but no admissible normalized Deep Assurance simulation result became observable within the bounded rehearsal window. Gate 07 was therefore failed rather than self-attested.
2. **Pre-authoritative branch collision:** an earlier rehearsal branch namespace was found already populated by another execution. That namespace was fenced and excluded before this clean v2 generation was adopted as authoritative.

Non-completed processes

- Required pinned fork-simulation evidence did not complete. This is the sole non-completed required evidence class in the authoritative v2 campaign and forces NO_GO.

Limitations

1. All named agent roles were executed serially by one ChatGPT runtime under the operator's no-poll rehearsal override. Production clean-room or independent-model separation is not demonstrated.
2. github-native-simulate-v1 evidence is unavailable after two bounded dispatches; auxiliary lifecycle evidence is not substituted.
3. The audited target is a synthetic basic ERC-20 fixture, not a production CurveYield release.
4. No live production deployment, deployed address, chain-state configuration, ownership state, or integration state was in scope.
5. This report is a point-in-time assessment and cannot guarantee absence of defects.

Evidence Index

Exact source

- Source commit: 248e5d5de42f8a111050fb8d2b7d587653833331
- Source Git blob: 0527d19901a07a12911f3a212ee2664df8219afc
- Source SHA-256: 45f03e840b749f0d34255402aacc3045a51dede8c6a08cafc7a83242c7c9ee9c

Pinned compile execution

- Request ID: dar-360e53dba12380d95c70b609fddd1488
- Request digest: 360e53dba12380d95c70b609fddd1488077e0fbf2a0d244dade0bacd381ddd37
- Dispatch commit: 23ceda46ecc48cdc4660b240d5a6dd050e92416e
- Workflow run: 31139567021
- Artifact ID: 8979310203
- Artifact ZIP SHA-256: 9e2b10d2600fc4aec078e923a23477c42572c2eb3ecc761e2e5853a2f9c374c2
- Normalized result SHA-256: 56c60df9656fec562da2d521fdee58f0d32513797d8abaef658f90a1144a595d
- Compiler output SHA-256: 60b18e9144701d717837109f0c1bdae5ed6eb4fffc392d0a1d49c5b2e12da596
- Compiler diagnostics: empty

- Tool versions: Node 22.23.1; solc 0.8.28

Pinned simulation dispatches

- Request 1: dar -a47cf351ba4c133fd5a2b35d2efe98b6; commit 83c1341ffd1658c422889efbfde26f5860b5808f
- Request 2: dar -71c87018670953e088088b307dbdc97f; commit 0443054fd15a5fa23eb9e7d2b2576f09f45b2ee3
- Requested environment: Ethereum block 20,000,000, Ganache fork engine, compiler 0.8.28
- Disposition: required normalized simulation evidence unavailable.

Auxiliary GitHub lifecycle evidence

- Run: 31139145798
- Job: 92745100030
- Artifact: 8979136771
- Artifact SHA-256: 1e0e621979ac1b984946bd0c755834fd65a28648ffff14c3c2c8d18f14e142879
- 13 checks passed; retained as corroboration only.

Finalization evidence

- Finalization snapshot SHA-256: d9fd7778bbafac5ee31fd8f1444a3acdac922fcdee8af0bd82ee014fe55bd341
- Separate-review decision: accepted for prepublication readiness.
- Publication manifest: PUBLICATION_MANIFEST_v2.json (external to report content).
- External artifact digest receipt: EXTERNAL_ARTIFACT_DIGEST_RECEIPT_v2.json.

Release Manifest

The authoritative release packet contains this Markdown report, the matching PDF, the supporting archive, the external artifact digest receipt, and the publication manifest/fetch-back receipt. Final binary digests are intentionally carried by external receipts rather than self-referential in-band hashes.

Conclusion

The fixed-supply ERC-20 fixture is small, dependency-free, and structurally strong: it has no privileged control plane, no external-call surface, no post-construction supply mutation, and straightforward balance/allowance accounting. Manual review and accepted pinned compilation found no Critical, High, Medium, or Low source vulnerability. Two non-blocking Notes remain for allowance and zero-value event semantics.

The final Deep Assurance outcome is nevertheless **COMPLETE + NO_GO** because the required pinned fork-simulation gate failed. This is an assurance verdict, not a claim that the contract contains a blocking exploit. A future same-source simulation evidence package could justify reevaluating that gate, but this report does not infer or fabricate the missing evidence.

Final Delivery Packet

- Markdown: Deep_Assurance_v16_2_ERC20_Rehearsal_Final_Report_v2.md
- PDF: Deep_Assurance_v16_2_ERC20_Rehearsal_Final_Report_v2.pdf

- Supporting archive: Deep_Assurance_v16_2_ERC20_Rehearsal_Supporting_Files_v2.zip
- Publication manifest: PUBLICATION_MANIFEST_v2.json
- Publication manifest fetch-back receipt: PUBLICATION_MANIFEST_FETCHBACK_RECEIPT_v2.json

completionStatus: COMPLETE securityVerdict: NO_GO